



第21章 软件架构脆弱性

王璐璐 wanglulu@seu.edu.cn

廖力 lliao@seu.edu.cn

目 录

- 21.1 引言
- 21.2 什么是软件脆弱性
- 21.3 软件架构脆弱性
- 21.4 小结

21.1 引言

- **脆弱性**是自然、动植物、动植物群体、社会、国家、制度等等众多属性中部分属性的集合，是**表示事物应对波动性、随机性、压力等等的变化趋势**。
 - 这个变化趋势如果不能够很好地应对波动性、随机性、压力等等，这表示这些事物应对波动性是脆弱的（vulnerable）；
 - 如果这个变化趋势，对事物没有影响，则表示这事物应对波动是强壮的（strong）

21.1 引言

- 系统安全受到各种安全威胁的根本原因是系统中存在脆弱性。
 - 网络与信息系统的脆弱性是一个系统问题：
 - 系统中物理装备（如计算机硬件、通信线路等）的脆弱性
 - 软件（如操作系统、网络协议簇、数据库管理系统、应用程序等）的脆弱性
 - 人员管理、规章制度、安全策略的脆弱性等等。

21.2 什么是软件脆弱性（I）

- 1. 软件脆弱性的定义
 - 通常情况下，我们认为**软件脆弱性**是导致破坏系统安全策略的系统安全规范、系统设计、实现和内部控制等方面的弱点。
 - 在软件开发过程中，软件脆弱性包含软件基础模型的脆弱性、软件架构设计的脆弱性、软件模块设计的脆弱性、软件接口设计的脆弱性、软件界面设计的脆弱性、数据库设计的脆弱性、架构模式和设计模式的脆弱性以及实现的脆弱性等等。

21.2什么是软件脆弱性（5）

- 2. 软件脆弱性特点：
 - （1）脆弱性是软件系统中隐藏的一个弱点，本身不会引起危害，但被利用后会产生严重的安全后果；
 - （2）在软件开发过程中，自觉或不自觉引入的逻辑错误是大多数脆弱性的根本来源；
 - （3）与具体的系统环境密切相关，系统环境的任何差异都有可能導致不同的脆弱性问题；
 - （4）旧的脆弱性得到修补或纠正的同时可能会引入新的脆弱性
- 因此，脆弱性问题会长期存在。

21.3 软件架构脆弱性（I）

- 软件架构脆弱性属于软件设计脆弱性或软件结构脆弱性的一种。
- 软件架构脆弱性是更高层次的软件结构脆弱性，也是更加重要的软件脆弱性问题。

21.3 软件架构脆弱性（2）

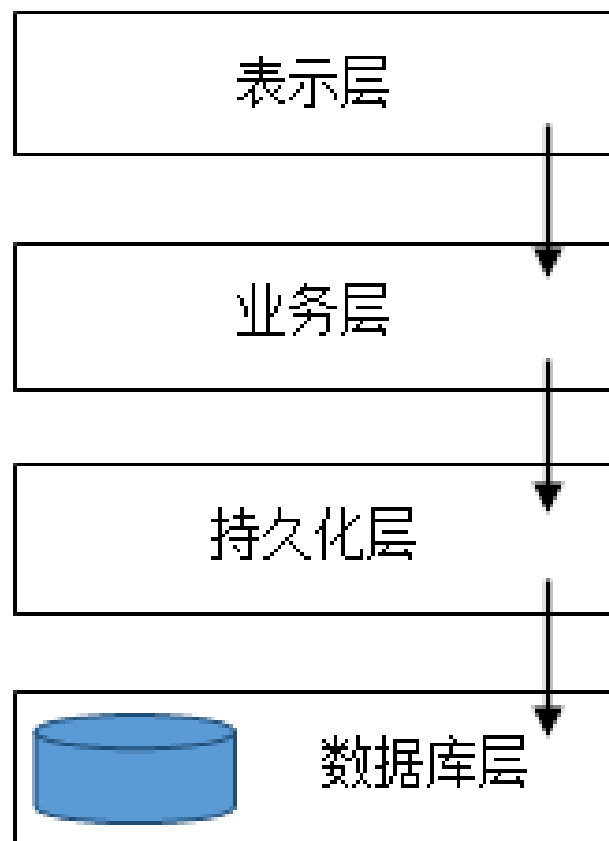
- 定义

- 软件（系统）架构设计存在一些明显的或者隐含的缺陷，攻击者可以利用这些缺陷攻击系统，或者当受到某个或某些外部刺激时，系统发生性能下降、稳定性下降、可靠性下降、安全性下降等等。如果软件架构具备这类缺陷，我们认为该软件架构是脆弱的，也就是软件架构脆弱性。

- 软件架构脆弱性通常与软件架构的风格（style）和模式（pattern）有关，不同风格和模式的软件架构，脆弱性体现和特点有很大不同

21.3 软件架构脆弱性（3）

1. 分层架构



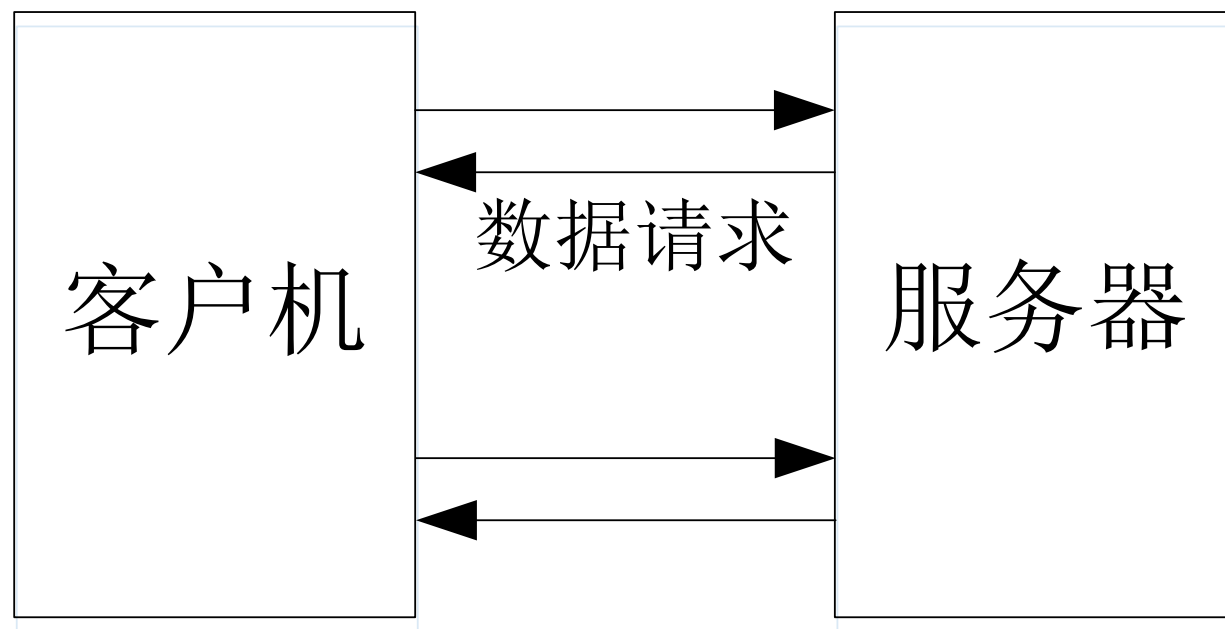
21.3 软件架构脆弱性（4）

1. 分层架构

- 分层架构脆弱性分析
- （1）一旦某个底层发生错误，那么整个程序将会无法正常运行，产生一些数据溢出、空指针、空对象的安全性问题，也有可能得出错误的结果。
- （2）将系统隔离为多个相对独立的层，要求在层与层之间引入通信机制。在使用面向对象方法设计的系统中，通常会存在大量细粒度的对象，以及它们之间的大量的消息交互——对象成员方法的调用。本来直来直去的操作，现在要层层传递，势必造成性能的下降。

21.3 软件架构脆弱性 (5)

2. C/S结构



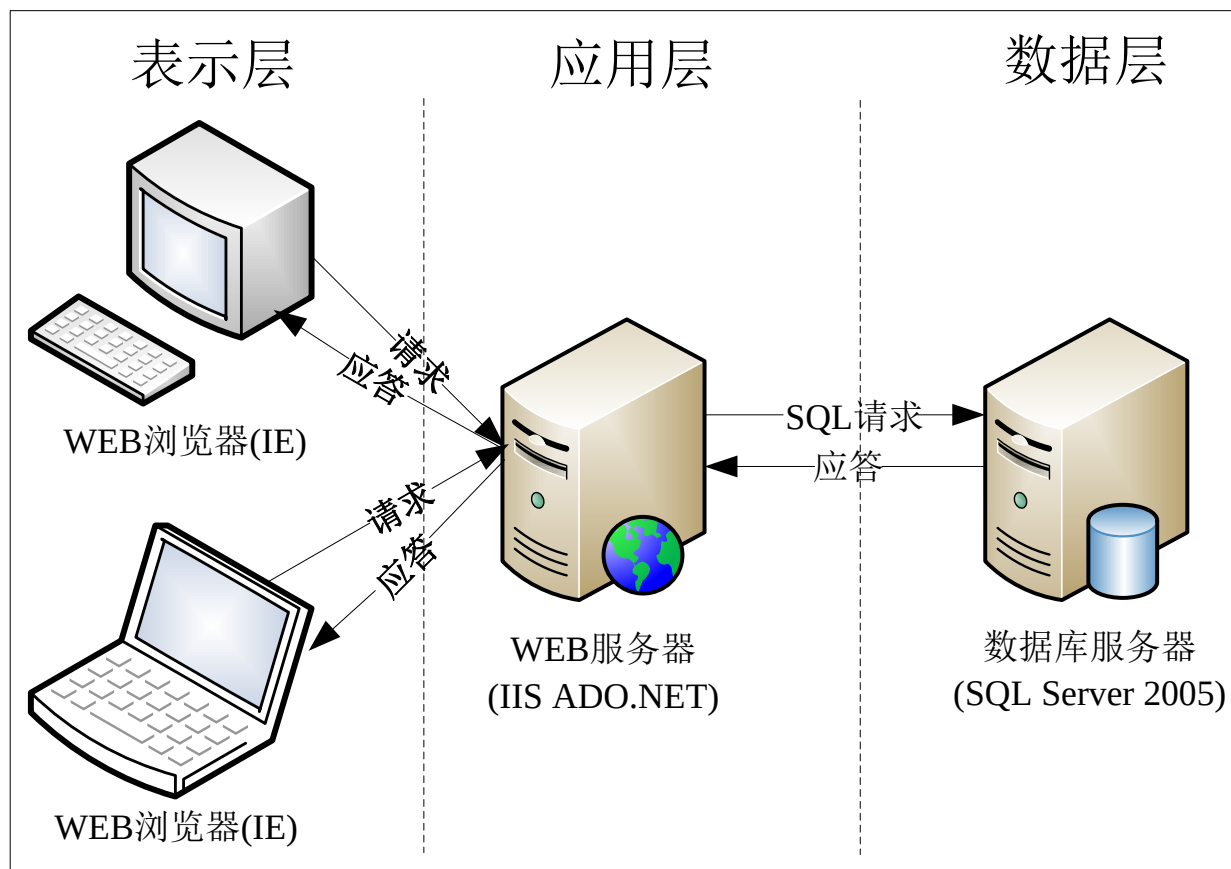
21.3 软件架构脆弱性 (6)

2. C/S架构

- C/S架构脆弱性分析
 - (1) 客户端需要安装专用的客户端软件，系统软件升级时，每一台客户机需要重新安装，其维护和升级成本非常高。
 - (2) 高昂的维护成本且投资大。
 - (3) 传统的C/S结构的软件需要针对不同的操作系统系统开发不同版本的软件，由于产品的更新换代十分快，代价高和低效率已经不适应工作需要。

21.3 软件架构脆弱性 (7)

3.B/S架构



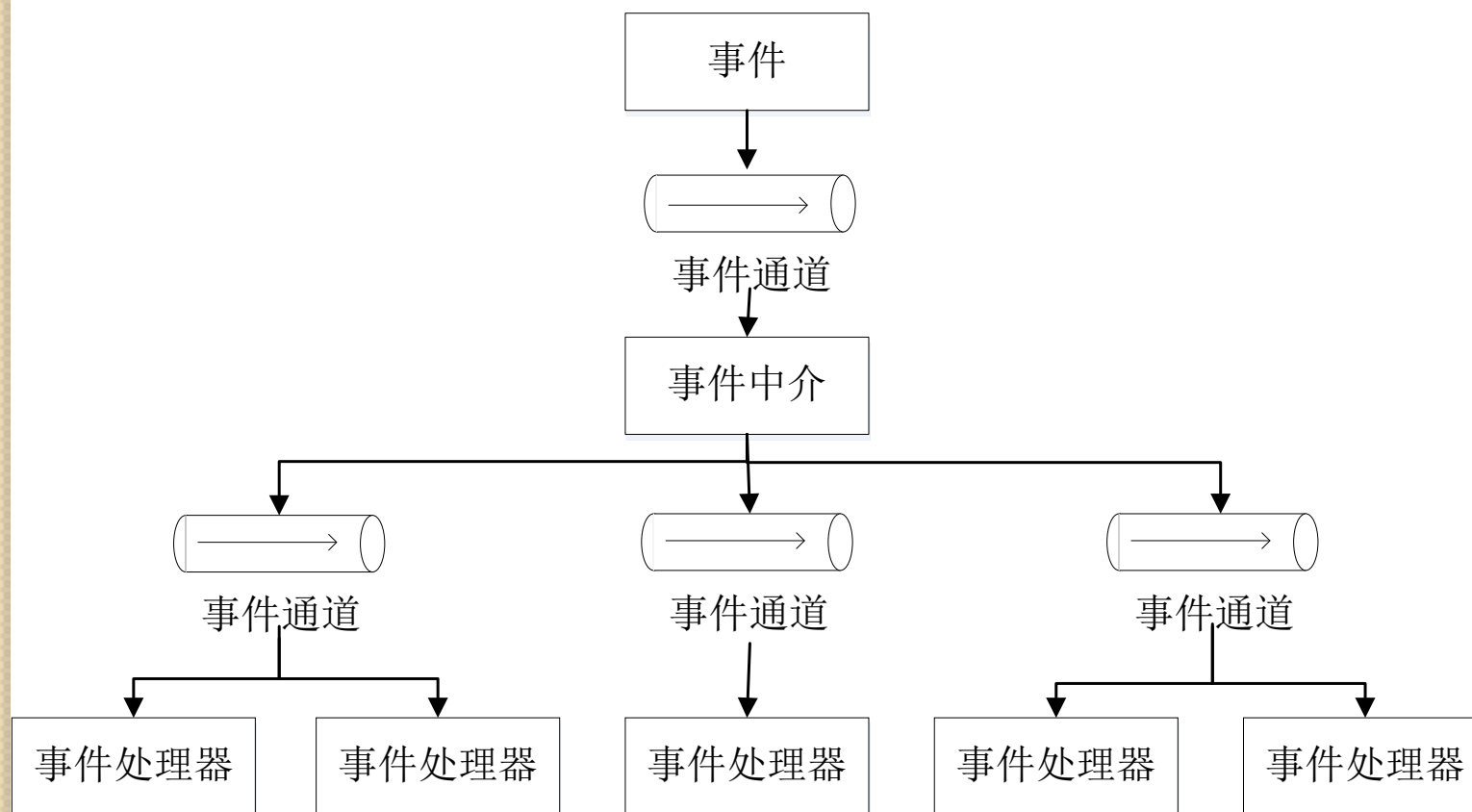
21.3 软件架构脆弱性（8）

3.B/S架构

- B/S架构脆弱性分析
 - （1）相对客户端来说，页面通用化，不突出个性。而且页面需要不断地动态刷新，尤其是当用户增多，网速慢等情况，服务器的压力将会增大，加载时间会变长。由于不需要安装客户端，客户端易扩展，B/S将面对大量的不可知用户。
 - （2）相对服务器来说，当用户增多时，服务器响应速度慢。功能虽然多样化，但是不能专门化，不能实现复杂的功能。服务器承担着重要的责任，数据负荷较重。一旦发生服务器“崩溃”等问题，后果不堪设想。

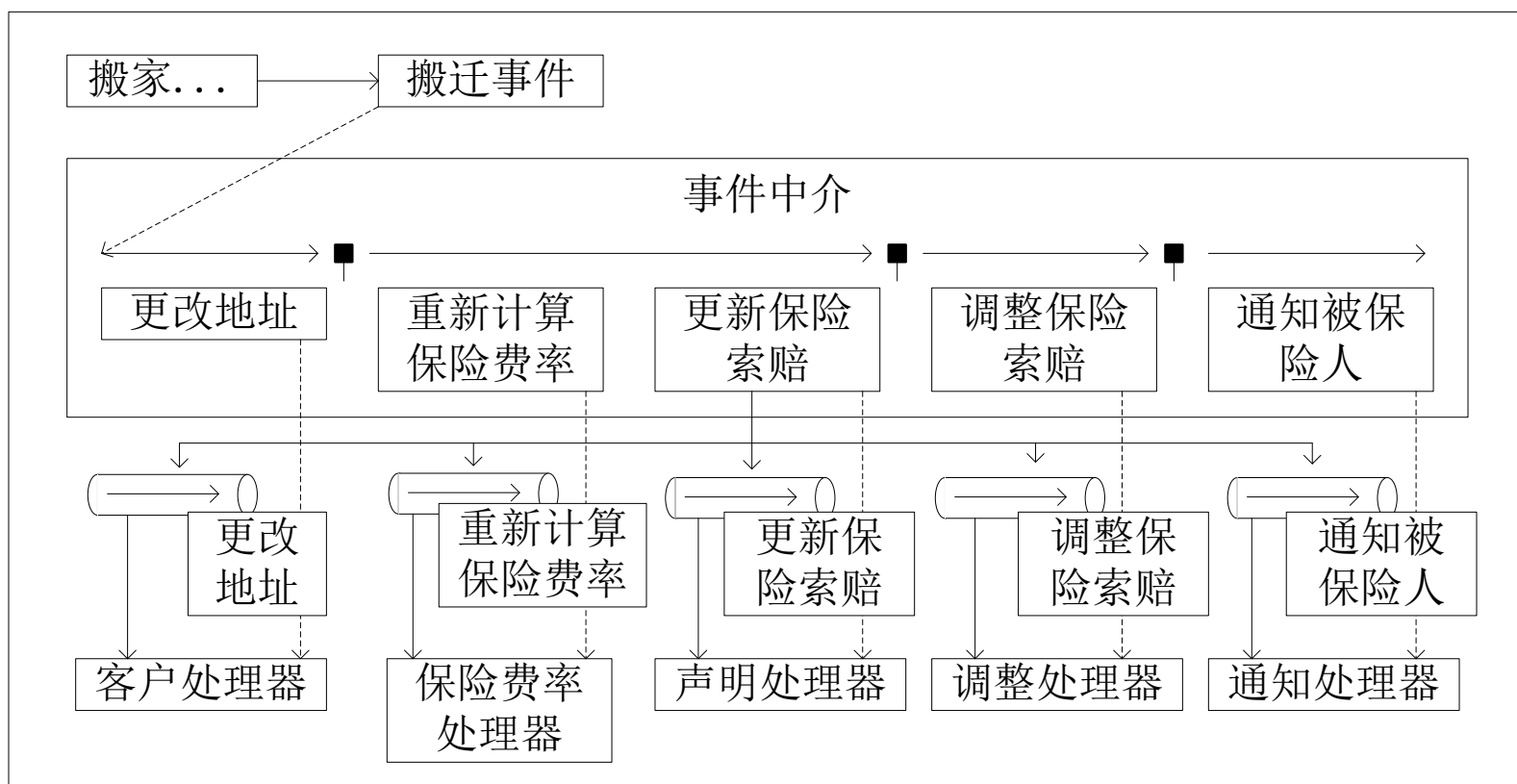
21.3 软件架构脆弱性 (9)

• 4.事件驱动架构



21.3 软件架构脆弱性 (10)

• 4.事件驱动架构



21.3 软件架构脆弱性（II）

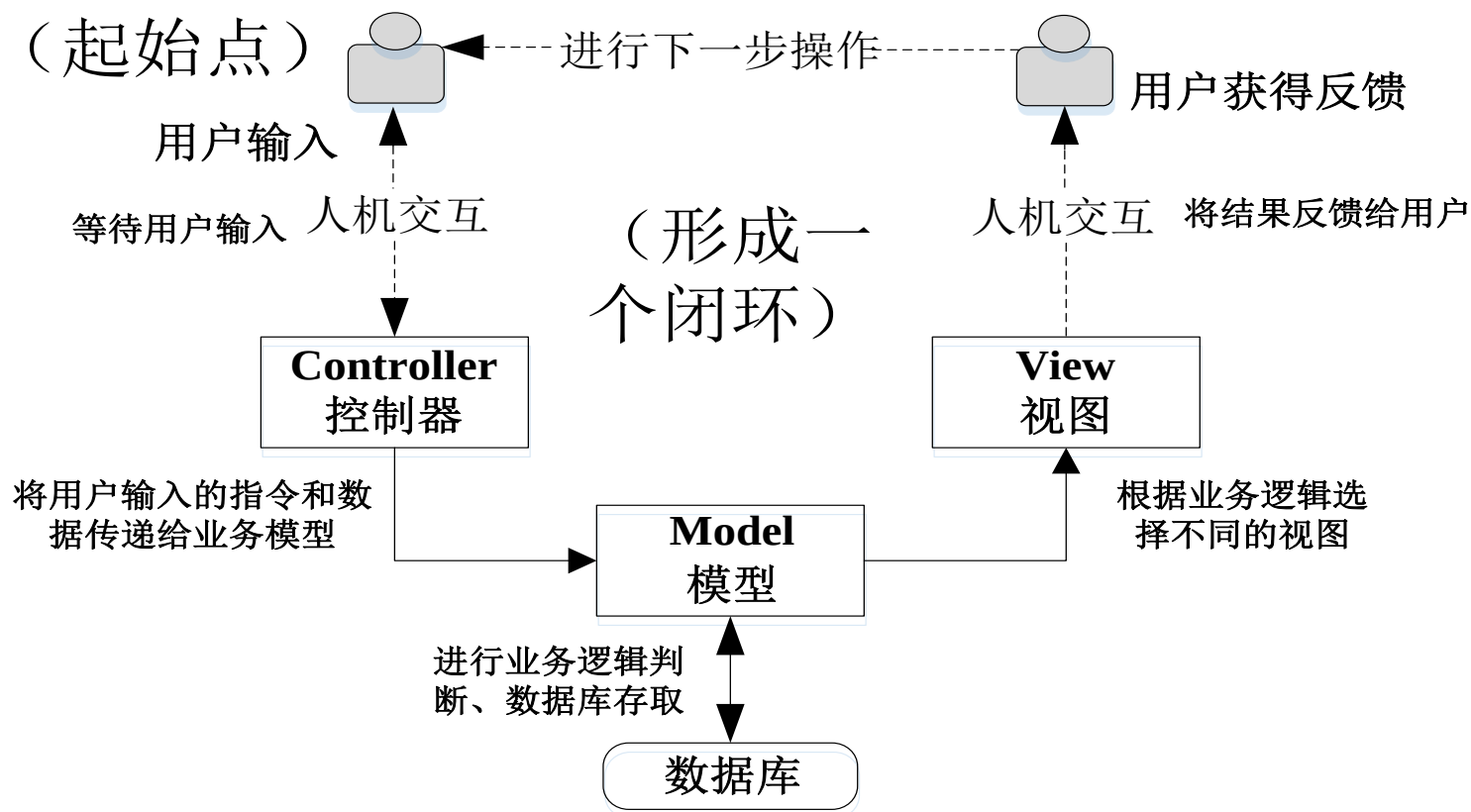
4.事件驱动架构

- 事件驱动架构脆弱性分析

- （1）组件削弱了自身对系统的控制能力。一个组件触及事件时，并不能确定响应该事件的其他组件及各组件的执行顺序。
- （2）不能很好地解决数据交换问题。
- （3）使系统中各组件的逻辑关系变得更加复杂。
- （4）事件驱动容易进入死循环，这是编程逻辑决定的。
- （5）虽然有机会实现有效利用cpu，但也存在高并发事件处理的可能造成系统响应问题,且易导致系统数据不正确、丢失数据现象。
- （6）因为可响应的流程基本都是固定的，如果操作不当，容易引发安全问题。

21.3 软件架构脆弱性 (12)

5.MVC模式



21.3 软件架构脆弱性 (13)

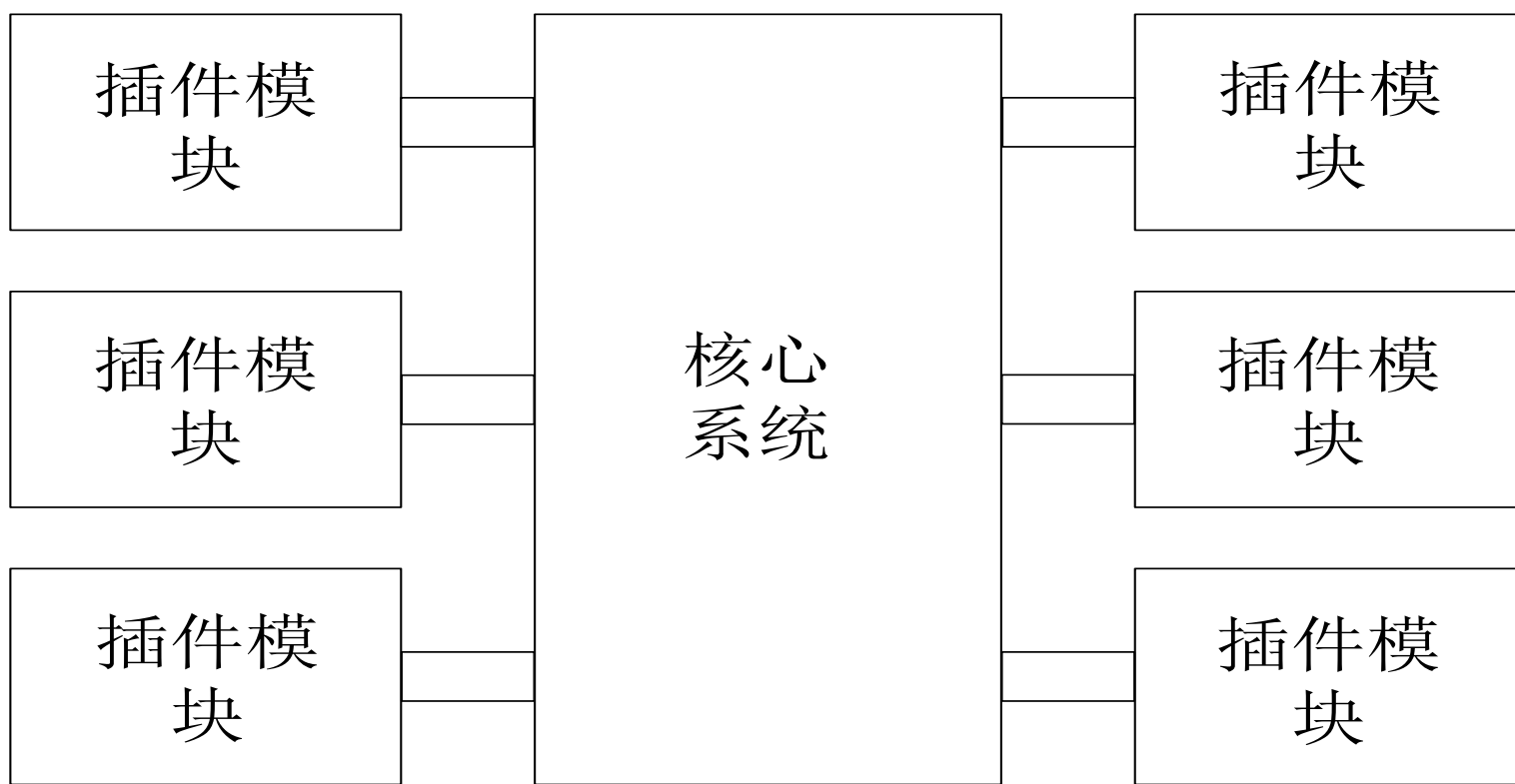
5.MVC模式

- MVC模式脆弱性分析

- (1)由于没有明确的定义，完全理解MVC并不是很容易。
- (2) MVC由于将应用分为三层，意味着代码文件增多。
- (3)不适合小型，中等规模的应用程序。
- (4)增加系统结构和实现的复杂性。
- (5)视图对模型数据的低效率访问。
- (6)一般高级的界面工具或构造器不支持模式。改造这些工具以适应MVC需要和建立分离的部件的代价很高

21.3 软件架构脆弱性（14）

6.微内核架构



21.3 软件架构脆弱性（15）

6. 微内核架构

- 微内核架构脆弱性分析

- （1）微内核构架难以进行良好的整体优化。
- （2）微内核系统的进程间相互通信开销也较单一内核系统要大的多。
- （3）通信损失率高。

7.管道/过滤器架构



21.3 软件架构脆弱性（17）

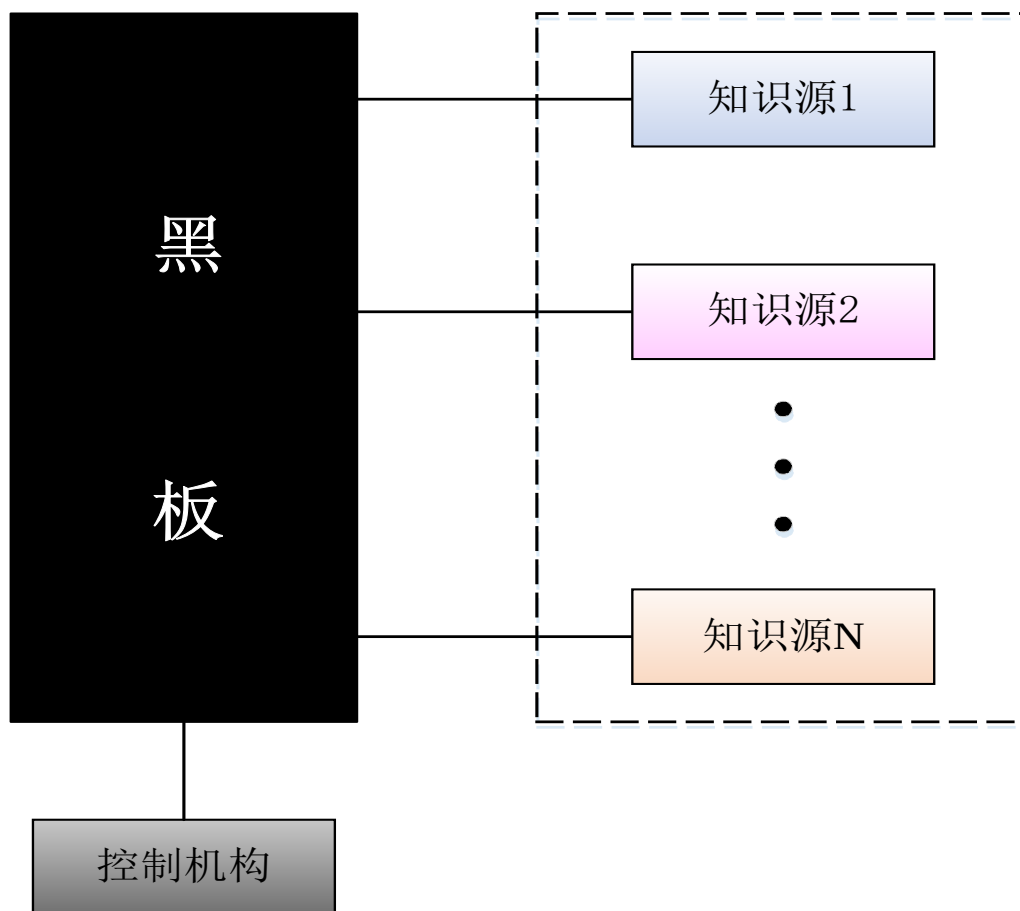
7.管道/过滤器架构

- 管道/过滤器架构脆弱性分析

- 每个过滤器的输入输出是独立的，一个过滤器的输出做为另外一个过滤器的输入，耦合度低；
- 若攻击者知道了某个过滤器的输入输出，有可能得出过滤器的功能，从而对系统的安全性造成威胁。
- 由于一个过滤器的输出作为另外一个过滤器的输入，若一个过滤器发生错误，使得整个错误在系统中放大，从而威胁系统的稳定性。

21.3 软件架构脆弱性 (18)

8.黑板模式



21.3 软件架构脆弱性（19）

8.黑板模式

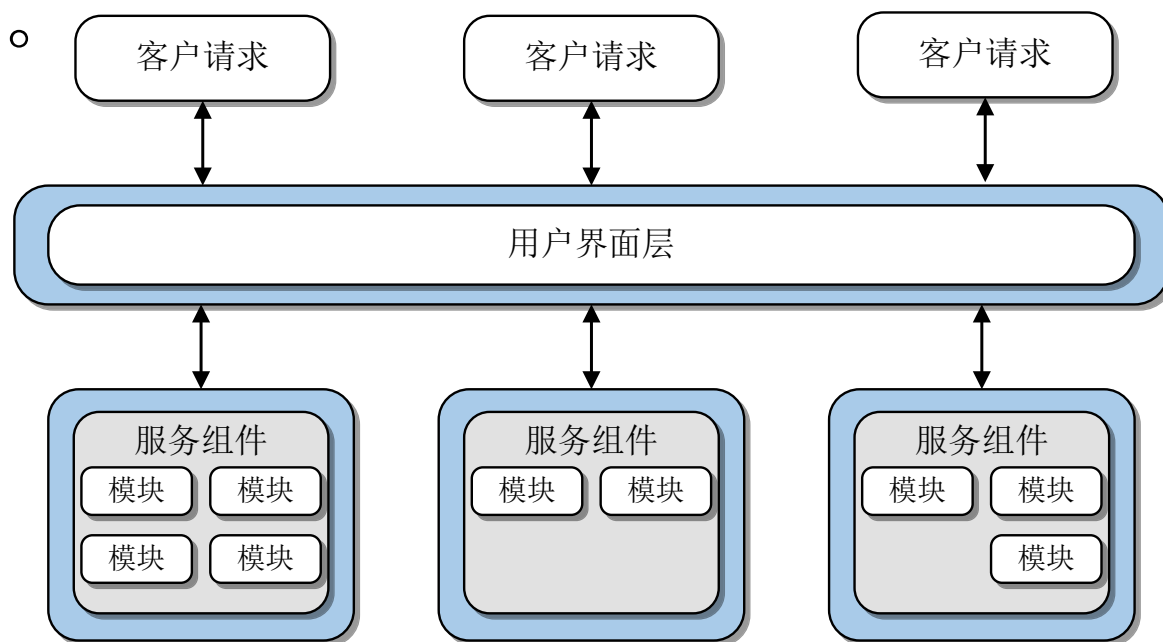
- 黑板模式脆弱性分析

- （1）不能确保期望结果：因为求解整个问题是通过多个知识源来进行的，而知识源的选择是通过控制机构中调度程序来选择的，如果知识源选择的不够恰当，可能会导致错误或者有误差的结果。
- （2）复杂，效率低下：通过上图我们就能看出，一个问题的求解可能需要多个知识源，并且需要排队，并且需要不停的修改黑板的状态，效率比较低。
- （3）不支持并行：首先控制机构中需要将知识源放入调度队列中排队，其次多个知识源共享黑板需要同步，因为它们是通过黑板进行通讯的，每个状态的改变可能会影响下一个状态的改变。

21.3 软件架构脆弱性 (20)

9. 微服务架构

- 微服务架构是一种架构模式，它提倡将单块架构的应用划分成一组小的服务，服务之间相互协调，相互配合，为用户提供最终价值。



21.3 软件架构脆弱性（21）

9.微服务架构

- 微服务架构脆弱性分析
 - （1）开发人员需要处理分布式系统的复杂性；开发人员要设计服务之间的通信机制，通过写代码来处理消息传递中速度过慢或者不可用等局部失效问题。
 - （2）服务管理的复杂性，在生产环境中要管理多个不同的服务实例，这意味着开发团队需要全局统筹。
 - （3）需要把握好应用微服务架构的时机

21.4 小结

- 软件脆弱性不仅与软件设计有关，还和软件实现有关，也和软件运维环境有关。
- 软件架构脆弱性不仅与软件安全还和最终软件产品的性能、可靠性和稳定性有很大的关系。
- 本章简要地讨论了软件脆弱性，并结合常见的软件架构模式，简要解析它们的组成以及分析了导致脆弱性的一些问题。